

MULTIMEDIA UNIVERSITY, MALAYSIA

Ethical Hacking Overview

ETHICAL HACKING AND PENETRATION TESTING
CCS6324 - 2530



Dr. Hafiz Adnan Hussain

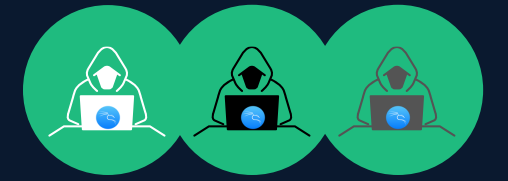


DISCLAIMER



- This course is designed to educate students on ethical hacking principles. The knowledge and techniques acquired must be used responsibly and not for any illegal or unauthorized activities.
- Each student is solely responsible for their actions.
- Do not investigate individuals, websites, servers or conduct any illegal activities on any system you do not have permission to analyze.
- The course content has been developed in good faith, drawing from the author's experience and reputable sources. While every effort has been made to ensure accuracy, the author does not guarantee absolute correctness. Students are encouraged to exercise discretion and actively engage in discussions by raising any questions or concerns during the course.

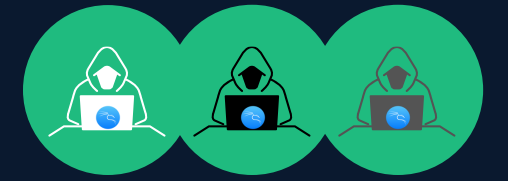
Learning Objectives



- Introduction to Ethical Hacking & Cybersecurity Landscape
- The Role of Security and Penetration Testers
- Penetration-Testing Methodologies (PTES, OWASP, NIST)
- Categories and Types of Penetration Tests (Black/White/Grey box)
- Legal and Ethical Considerations - Law of the land
- Recent Hacking Incidents and Case Studies

Learning Outcomes: By the end of this lecture, you will understand the fundamentals of ethical hacking, legal boundaries, and penetration testing frameworks.

What is Ethical Hacking?



What picture comes to your mind when you think of Hacking?

Ethical Hacking is the authorized practice of bypassing system security to identify potential data breaches and threats in a network.

Malicious Hacking

- Unauthorized access
- Criminal intent
- Data theft/destruction
- Financial gain
- Illegal activities

Ethical Hacking

- Authorized access
- Security improvement
- Vulnerability discovery
- Protect organizations
- Legal & documented

Key Point: Ethical hackers use the same techniques as malicious hackers, but with permission and for defensive purposes.

Cybersecurity Landscape 2025



Current Threats and Trends:

- Ransomware attacks increasing by 150% year-over-year
- Supply chain attacks targeting third-party vendors
- AI-powered phishing becoming more sophisticated
- IoT vulnerabilities exposing critical infrastructure
- Cloud misconfigurations leading to data breaches

Industry Statistics (2024-2025):

- Average cost of data breach: \$4.45 million USD
- Time to identify breach: 277 days (average)
- Cybercrime expected to cost \$10.5 trillion globally by 2025
- 3.5 million unfilled cybersecurity positions worldwide

Why Ethical Hacking Matters

Importance of Security and Compliance

For Organizations

- Identify vulnerabilities before attackers
- Comply with regulations (PDPA, GDPR)
- Protect customer data and trust
- Prevent financial losses
- Maintain business continuity

For Society

- Protect critical infrastructure
- Secure healthcare systems
- Defend financial institutions
- Safeguard national security
- Privacy protection

Quote: "The best defense is a good offense. Understanding how systems can be compromised is essential to protecting them."



The Role of Security & Penetration Testers

Core Responsibilities:

- **Vulnerability Assessment:** Identify security weaknesses in systems, networks, and applications
- **Penetration Testing:** Simulate real-world attacks to exploit vulnerabilities
- **Security Auditing:** Review security policies, configurations, and controls
- **Report Writing:** Document findings and provide remediation recommendations
- **Client Communication:** Explain technical risks to non-technical stakeholders

Required Skills:

Technical:

- Networking (TCP/IP, DNS, routing)
- Operating Systems (Linux, Windows)
- Programming (Python, Bash, PowerShell)
- Web technologies (HTTP, databases)

Soft Skills:

- Problem-solving mindset
- Attention to detail
- Communication skills
- Ethical integrity

Career Paths in Ethical Hacking

Role	Description	Avg. Salary (Malaysia)
Penetration Tester	Simulate attacks on systems to find vulnerabilities	RM 60k - 120k/year
Security Analyst	Monitor and respond to security incidents	RM 50k - 90k/year
Red Team Operator	Advanced adversary simulation and testing	RM 80k - 150k/year
Security Consultant	Advise organizations on security strategy	RM 70k - 130k/year
Bug Bounty Hunter	Find vulnerabilities for rewards	Variable (up to \$1M+)

Key Certifications: CEH, OSCP, GPEN, GWAPT, PNPT, eWPT, CompTIA PenTest+

Penetration Testing Methodologies

Standardized frameworks ensure comprehensive and consistent testing

1. PTES (Penetration Testing Execution Standard)

- **Pre-engagement:** Scope definition, rules of engagement
- **Intelligence Gathering:** OSINT and reconnaissance
- **Threat Modeling:** Identify attack vectors
- **Vulnerability Analysis:** Find weaknesses
- **Exploitation:** Attempt to compromise systems
- **Post-Exploitation:** Maintain access, pivot
- **Reporting:** Document findings and recommendations

To be continued...

Other Testing Methodologies

2. OWASP Testing Guide

- Focus on **web application security**
- OWASP Top 10 vulnerabilities framework
- **Covers:** Authentication, session management, input validation, cryptography
- **Best for:** Web app penetration testing

3. NIST SP 800-115

- U.S. National Institute of Standards and Technology framework
- Government and compliance-focused
- Phases: Planning, Discovery, Attack, Reporting
- Best for: Enterprise and regulated industries

4. OSSTMM (Open-Source Security Testing Methodology Manual)

- Scientific approach to security testing
- Covers: Networks, wireless, human security, physical security
- Provides metrics and measurements

The Penetration Testing Process



Categories & Types of Penetration Tests

APPROACHES TO PENETRATION TESTING

Based on Knowledge Level:

Type	Tester Knowledge	Simulates	Advantages
Black Box	Zero knowledge	External attacker	Realistic, unbiased
White Box	Complete knowledge	Insider threat	Comprehensive, efficient
Grey Box	Partial knowledge	Compromised account	Balanced approach

Most Common: Grey box testing provides a balance between realism and thoroughness.

Categories & Types of Penetration Tests

Network Penetration

Tests internal and external network security, identifying vulnerabilities in firewalls, routers, switches, and servers.

Web Application Penetration

Focuses on web apps and APIs, testing for OWASP Top 10 vulnerabilities like SQL injection, XSS, and authentication flaws.

Wireless Network Penetration

Assesses WiFi security, testing WPA2/WPA3 encryption, rogue access points, and wireless attack vectors.

Social Engineering

Tests human vulnerabilities through phishing, vishing, pretexting, and physical security bypasses.

Physical Penetration

Assesses physical security controls like locks, badges, security guards, and surveillance systems.

Red Team vs Blue Team vs Purple Team

EXPLORING DIFFERENT TESTING METHODOLOGIES

Red Team

Role: Offensive security

- Simulate real attackers
- Find vulnerabilities
- Test detection capabilities
- Full-scope engagement

Blue Team

Role: Defensive security

- Monitor and defend systems
- Detect attacks
- Respond to incidents
- Improve security posture

Purple Team

Role: Collaboration between Red and Blue

- Knowledge sharing between teams
- Continuous improvement
- Feedback loop for defense enhancement

This Course: Focuses primarily on Red Team (offensive) skills, with awareness of Blue Team defensive measures.

Legal and Ethical Considerations



Key Legal Principles:

- **Get explicit permission:** Written authorization before testing
- **Define scope clearly:** What systems, time windows, methods allowed
- **Respect boundaries:** Never exceed authorized scope
- **Protect data:** Treat discovered information as confidential
- **Report responsibly:** Disclose vulnerabilities properly

Rules of Engagement (ROE):

- Testing timeframe and windows
- Target systems and IP ranges
- Prohibited actions (e.g., DoS attacks)
- Emergency contact procedures
- Data handling and confidentiality agreements

⚠ CRITICAL: Always Get Written Authorization!

Unauthorized access to computer systems is ILLEGAL, even if your intentions are good.

LAW OF THE LAND:

Malaysian Cybersecurity Laws

UNDERSTANDING KEY REGULATORY FRAMEWORKS AND PENALTIES

Computer Crimes Act 1997

- Section 3: Unauthorized access - Up to 5 years imprisonment or RM 50,000 fine
- Section 4: Unauthorized access with intent to commit fraud - Up to 10 years
- Section 5: Unauthorized modification - Up to 7 years or RM 100,000 fine

Personal Data Protection Act (PDPA) 2010

- Protects the personal data of individuals
- Organizations must secure data properly
- Penalties up to RM 500,000 or 3 years imprisonment

Communications and Multimedia Act 1998

- Section 233: Improper use of network facilities
- Covers online threats, harassment, and offensive content

Remember: "I was just testing" or "I was learning" is NOT a legal defense for unauthorized access!



Ethical Hacker's Code of Conduct

ESSENTIAL GUIDELINES FOR RESPONSIBLE ETHICAL HACKING

CORE ETHICAL PRINCIPLES:

1. **Obtain proper authorization** before any testing
2. **Respect privacy** - don't access unnecessary data
3. **Maintain confidentiality** - protect client information
4. **Report all findings** - even if uncomfortable
5. **Do no harm** - avoid disrupting systems
6. **Continuous learning** - stay updated on threats
7. **Give back** - contribute to security community

“

“Keep private and confidential information gained in your professional work to maintain trust and integrity.”

– EC-Council

Professional Standards: Most certifications (**CEH, OSCP**) require agreeing to strict ethical codes.

Recent Hacking Incidents (2023-2025)

Global Cybersecurity Incidents:

1. MOVEit Transfer Zero-Day Exploit (2023)

Impact: Over 2,000 organizations affected globally

Attack Vector: SQL injection vulnerability in file transfer software

Lesson: Supply chain vulnerabilities can have massive cascading effects

2. MGM Resorts Ransomware Attack (2023)

Impact: \$100 million in losses, casino operations shut down

Attack Vector: Social engineering via LinkedIn, compromised VPN credentials

Lesson: Human vulnerabilities remain the weakest link

3. Change Healthcare Cyberattack (2024)

Impact: 100+ million patient records compromised, healthcare disruption

Attack Vector: Ransomware via compromised credentials

Lesson: Healthcare sector remains high-value target

Malaysian Cybersecurity Incidents:

1. Malaysian Communications & Multimedia Commission (MCMC) Data Leak (2024)

Impact: Sensitive government communications exposed

Cause: Database misconfiguration

2. Banking Sector Phishing Campaigns (Ongoing)

Impact: Millions lost to fake banking apps and SMS phishing

Attack Vector: Social engineering, fake mobile apps

Lesson: Public Awareness crucial for defense

3. E-Commerce Platform Breaches (2023-2024)

Impact: Customer data and payment information compromised

Cause: SQL injection, weak authentication

Trend: Malaysian organizations increasingly targeted due to growing digital economy and sometimes weaker security postures compared to Western counterparts.

Recent Hacking Incidents (References)

Heading	URL
Cyber Threats	https://cybermap.kaspersky.com
World's Biggest Data Breaches & Hacks	https://informationisbeautiful.net/visualizations/worlds-biggest-data-breaches-hacks
SR-029.022025: MyCERT Report - Cyber Incident Quarterly Summary Report - Q4 2024	https://www.mycert.org.my/portal/advisory?id=SR-029.022025
Malaysia hit by more than 3,000 cyber attacks each day	https://www.nst.com.my/news/nation/2024/03/1032394/malaysia-hit-more-3000-cyber-attacks-each-day
Telekom Malaysia customer data	https://www.thestar.com.my/tech/tech-news/2024/01/26/hacker-alleges-to-have-stolen-telekom-malaysias-customer-database-with-nearly-20-million-effective-user-data
Other breaches	https://www.lowyat.net/data-breaches/ https://www.malaymail.com/news/malaysia/2022/12/31/major-data-breaches-in-malaysia-in-the-past-24-months/47722

Current Attack Trends & Techniques

TOP ATTACK VECTORS (2024-2025)

Attack Type	Frequency	Primary Targets
Ransomware	Every 11 seconds	Healthcare, Government, Education
Phishing	3.4 billion emails/day	Financial services, Retail
Supply Chain	Increasing 300%	Software vendors, MSPs
IoT Exploits	Growing rapidly	Smart devices, Industrial systems
AI-Powered Attacks	Emerging threat	All sectors

Key Insight: Attackers increasingly use automation, AI, and sophisticated social engineering rather than just technical exploits.



Case Study: SolarWinds Supply Chain Attack

SolarWinds Supply Chain Attack



Background (2020, still relevant):

One of the most sophisticated cyberattacks in history, demonstrating modern threat actor capabilities.

Attack Timeline:

- **September 2019:** Initial network compromise
- **March 2020:** Malicious code inserted into Orion software
- **May-June 2020:** Trojanized updates distributed to 18,000 customers
- **December 2020:** Attack discovered by FireEye

Attack Methodology:

- 1. Initial Access:** Compromised SolarWinds build environment
- 2. Code Injection:** Backdoor (SUNBURST) added to legitimate software
- 3. Distribution:** Signed updates pushed to customers automatically
- 4. Lateral Movement:** Attackers moved through victim networks
- 5. Data Exfiltration:** Sensitive information stolen over months

Impact: U.S. government agencies, Fortune 500 companies, critical infrastructure compromised.
Estimated cost: billions of dollars.

Lessons from Recent Incidents

For Defenders:

- Zero-trust architecture essential
- Supply chain security critical
- Continuous monitoring required
- Incident response plans must be tested
- User security awareness training
- Regular penetration testing

For Attackers (What We Study):

- Patience and persistence pay off
- Social engineering highly effective
- Supply chain = force multiplier
- Living-off-the-land techniques avoid detection
- Legitimate tools weaponized
- Multi-stage attacks harder to detect

Your Role as Ethical Hackers: Understand attacker mindset and techniques to better defend organizations. Think like attackers but act ethically.

AI & ML in Cybersecurity - Overview

Key Roles

- AI & ML are powerful allies in detecting and preventing cyber attacks.
- Cyber threats have evolved from the Morris Worm (1988) to modern ransomware and cloud security risks.
- Today's attacks are complex, well-funded, and target organizations globally.

Why AI & ML Matter

- Analyze massive volumes of data in real time.
- Identify patterns & anomalies indicating potential threats.
- Detect fraudulent activities such as phishing, pharming, and financial scams.
- Enable faster, more accurate response to zero-day and sophisticated attacks.

AI & ML Threat Detection Techniques

Detection Methods

- Heuristic-based: Recognizes general malware characteristics.
- Rule-based: Uses predefined rules to flag malicious behavior.
- Statistical Anomaly Detection: Flags outliers (e.g., unusual data uploads).
- User & Entity Behavior Analytics (UEBA): Monitors users and devices for abnormal actions (e.g., unauthorized file access or foreign emails).

Future Trends

- Automation and AI processes are key for early threat detection and response.
- Continuous advancement in AI/ML is reshaping how organizations monitor, detect, and respond to cyber attacks.



Conclusion & Next Steps

Engage in ethical hacking practice and continuous learning



Thank You

QUESTIONS?

